



Universiteit
Leiden
The Netherlands

Access Control and Identity Management

Lecture Handout

Eleftheria Makri

2025-2026

1. Access Control

- **Access Control:** Access Control is the process of allowing only authorized users, programs, or other computer systems (i.e., networks) to observe, modify, or otherwise take possession of the resources of a computer system. It is also a mechanism for limiting the use of some resources to authorized users.
- **Access Control Mechanism:** Security safeguards (i.e., hardware and software features, physical controls, operating procedures, management procedures, and various combinations of these) designed to detect and deny unauthorized access and permit authorized access to an information system.

2. Identification, Authentication, and Authorization

Identification is the assertion of a unique identity for a person or system and is the starting point of all access control. The objective of identification is to bind a user to the appropriate controls based on that unique user instance, providing additionally accountability.

Authentication is the process of verifying the identity of the user. This is accomplished by providing some private data that only the user has access to or knowledge of, and verifies the identity.

The final step in the process is **authorization**, which is the process of defining the specific resources a user needs and determining the type of access to those resources the user may have.

Thus:

- Identification provides uniqueness
- Authentication provides validity
- Authorization provides control

2.1 Identification Methods

Identification Badges: are the most common form of physical identification and authorization in organizations. Generally ID badges should be worn by the employees at all times while at the organization premises, so as to allow constant control. Employees, and especially security personnel are expected to pay close attention to ID badges. A more successful type of badge is the access badge, which allows entry to secured areas, only upon verification of the badge's validity and permissions for that area (electronically). Most of the times companies combine ID and access badges in one, to strengthen the resulting security of the mechanism.

User ID/Username: is the most common identification mechanism for information systems, and it is unique per user.

Account Number/PIN: Account numbers have the exact same functionality as user IDs. Most commonly they are used for banking transactions, and in these instances in combination with a PIN number, which is used for the authentication part of the process.

MAC Address: MAC addresses are used to uniquely identify devices on a network. It is a 48-bit number that is globally unique per network device, but nowadays can be changed by software tools. Thus, MAC addresses are no longer considered a strong identifier, let alone a strong authenticator.

IP Address: IP (internet protocol) addresses are used to identify the logical location of a network device, instead of the physical one determined by the MAC address. Each IP address in a specific subnet must be unique. Given that IP addresses are assigned in software they cannot be considered strong identifiers.

Radio Frequency Identification (RFID): The RFID tag is a small label that can be embedded in almost any object, including product shipping pallets, passports, consumer goods, and even human beings, and it uniquely identifies them. When the RFID tag comes in the proximity of an RFID reader, the information of the label is being read, and the object is identified. Given how small the RFID tags are, and the ease of use of this technology it has been spread widely. However, it also raises privacy concerns, where information can be read by attackers in the proximity of the victim, without the owner's (victim's) consent (e.g., biometric passport, RFID tag injected people, etc.).

E-Mail Address: Using e-mail addresses for identification on the Internet has become commonplace, because of the fact that e-mail addresses are globally unique and widely used. However, the ease of deploying e-mail spoofing attacks nowadays, should be taken into account before using e-mail addresses as identifiers.

2.2 Authentication Methods

Once an identity is established it must be authenticated. There are three fundamental types of authentication, also known as *factors*:

- **Authentication by knowledge**—something a person knows
- **Authentication by possession**—something a person has
- **Authentication by characteristic**—something a person is

Single-factor authentication is the employment of one of these factors, two-factor authentication is using two of the three factors, and three-factor authentication is the combination of all three factors. The latter two are most commonly known as **multifactor authentication (MFA)**.

Authentication by knowledge

- Passwords and Passphrases
 - They have to be difficult to guess, but easy to remember
 - Their confidentiality is essential → not written down; never sent in plaintext over the network
 - When stored locally password files should be securely hashed
- Graphical passwords
 - Invented to combat keystroke loggers
 - They can be implemented by displaying pictures, one of which is the preselected one by the user
 - They can be implemented by a “virtual” keyboard, where the user can “click” his/her password through

Authentication by possession

Two types:

- Asynchronous: Challenge-response technology
- Synchronous: Based on an event, location, or time-based synchronization between the requestor and authenticator
- Static authentication devices
 - *Memory Cards*: no processing capabilities; recently being replaced by USB authentication devices; data on the cards are unprotected.
 - *Smart Cards*: embedded semiconductor chip → (limited) processing power; major advantage to memory cards is that log-on is done by the reader instead of the host → no password exposure while in transit to the host; Common uses of smart cards:
 - Secure log-on
 - Secure e-mail/digital signatures
 - Secure Web access/remote access
 - Virtual private networks (VPNs)
 - Hard disk encryption

Smart cards can be:

 - Contact cards, or
 - Contactless cards (aka proximity cards)
- Other possession-based authentication devices (mainly USB attachable)

Authentication by Characteristic (Biometrics)

Two types of biometrics:

- **Physiological**
 - Human fingerprints (even USB memory fobs can have fingerprint readers embedded)
 - Hand geometry (measuring amongst other things, tension in the tendons in the hand, temperature, finger length, bone length, and hand width)
 - Retina scans
 - Iris scans
 - Facial geometry (skull structure and tissue density)
 - Vascular scans (examines the patterns and thickness of veins in one's face or hand)
- **Behavioral**
 - Voice pattern
 - Keystroke dynamics
 - Signature dynamics

Biometric Accuracy

Still nowadays biometric technology suffers from inaccuracy in the measurements of the characteristics to be verified. This mainly comes from the variability of humans and their surroundings. Biometrics, in contrast to for example password-based authentication are not static, but rather seek for (mathematical) estimations of the measurements.

The three categories of biometric accuracy measurement are:

- **False Reject Rate** (Type I Error): When authorized users are falsely rejected as unidentified or unverified.
- **False Accept Rate** (Type II Error): When unauthorized persons or imposters are falsely accepted as authentic.
- **Crossover Error Rate** (CER): The point at which the false rejection rates and the false acceptance rates are equal. The smaller the value of the CER, the more accurate the system.

Biometric Considerations

- Resistance to counterfeiting
- Data storage requirements
- User acceptance
- Reliability and accuracy (*Speed of enrollment and authentication is also a matter of reliability*)

3. Identity Management

Identity Management

Identity management is the set of technologies aiming to increase the efficiency of the diverse user and technical environment of today's modern organization. The main responsibility of identity management systems is to centralize and streamline user identities, authentication, and authorization. Today's complex IT infrastructure mandates the use and collaboration of various services and applications, all of which require some sort of identity management.

User Access Management

An organization must have a formal procedure to control the allocation of credentials and access rights to information systems and services, covering the whole life cycle of user access (from initial registration to decommissioning). Within this documented processes of all different steps within the user access management lifecycle, password selection and management play a vital role.

Identity Management System (IMS)

An Identity management system (IMS) is a system to **create**, **use**, and **revoke** user identities, with the following challenges:

- It can be tricky for large organizations and complex systems
- Various security requirements can apply depending on the use case:
 - privacy/anonymity/full transparency
 - strong link to physical identity
 - revocability
 - unforgeability

4. Access Control Policies

Different classes of access control policies (schemes) determine who sets and who controls the policy, and access control rules are based on various groupings of identities.

Examples of AC policies (not mutually exclusive):

- **Discretionary Access Control (DAC):** Discretionary Access Control means that the controls are placed on data by its owner. Thus, the owner determine who has access to the data, and their exact privileges. This is an early form of access control, initially adopted by universities, even before the evolution of personal computers. This user-centric approach is nowadays widely deployed by all mainstream operating systems.
- **Mandatory Access Control (MAC):** Mandatory Access Control means that the controls are determined by the system, and are based on the organization's policy. The controls are enforced based on the users' clearances, and the objects' classifications. The organization's

security policy, is now, in contrast to DACs enforced by the system, instead of the data owner. MAC is deployed in highly sensitive environments and is user cooperative only to minimize user's accesses, and never to bypass the by-default stance. This is to enforce the need-to-know principle.

- **Non-Discretionary Access Control:** Non-discretionary Access Control is also based on the assignment of permissions to read, write, and execute files on a system. However, unlike discretionary access control, where the owner specifies those permissions, nondiscretionary access control requires the administrator of a system to do so.
 - **Role-based access control (RBAC):** In such a system, access is based on the roles (job functions) of a user within the organization. This kind of grouping of permissions allows administrators to simplify access control strategies. The basic RBAC architectures are:
 - **Non-RBAC:** Simply user-granted access to data or applications (same as with ACLs). No groups or roles defined.
 - **Limited RBAC:** Users mapped to roles within single applications, instead of through an organization-wide role structure. There are additionally non-RBAC applications.
 - **Hybrid RBAC:** There is here a clear role assignment to the user, applied to multiple applications or systems. There are also instances of roles specified only under certain applications.
 - **Full RBAC:** Control is always based on roles defined by the organizational policy, uniformly applied to all access controls of applications and systems enterprise-wide.

5. Data Access Controls

Access Control Lists (ACLs), a common form of controls, typically have two pieces of data: a keyword, and an action. Keyword patterns differ per application. E.g., an ACL at a router may have IP addresses as keywords, and the instructions on whether to block or allow traffic from an to this networks, as actions.

An **Access Control Matrix (ACM)** is an ACL in the form of a table. Subjects and objects are identified and listed as rows and columns of the table respectively, and permissions can be easily then marked in the table.

6. Multi-level Security Policies

6.1 Bell–LaPadula

The **Bell–LaPadula Model** (abbreviated BLP) is a state machine model used for enforcing access control in government and military applications. It was developed by David Elliott Bell and Leonard J. LaPadula, for the U.S. Department of Defense (DoD) multilevel security (MLS) policy. The model is a formal state transition model of computer security policy that describes a set of access control rules which use security labels on objects and clearances for subjects. Security labels range from the most sensitive (e.g., “Top Secret”), down to the least sensitive (e.g., “Unclassified” or “Public”).

Rules:

- The **Simple Security Property** - a subject at a given security level may not read an object at a higher security level (**no read-up**). (MAC)
- The **star-property** - a subject at a given security level must not write to any object at a lower security level (**no write-down**). (MAC)
- The **Discretionary Security Property** - use of an access matrix to specify the discretionary access control. (DAC)
- Additional -not always implemented-, **Strong star property** – writes only at the same level of the subject (for integrity)

6.2 Biba

The **Biba Model** or Biba Integrity Model developed by Kenneth J. Biba in 1977, is a formal state transition system of computer security policy that describes a set of access control rules designed to ensure data integrity. Data and subjects are grouped into ordered levels of integrity. The model is designed so that subjects may not corrupt objects in a level ranked higher than the subject, or be corrupted by objects from a lower level than the subject.

In general, preservation of data *integrity* has **three goals**:

- Prevent data modification by unauthorized parties
- Prevent unauthorized data modification by authorized parties
- Maintain internal and external consistency (i.e., data reflects the real world)

Rules:

- The **Simple Integrity Axiom** states that a subject at a given level of integrity must not read an object at a lower integrity level (**no read down**).
- The **Star Integrity Axiom** states that a subject at a given level of integrity must not write to any object at a higher level of integrity (**no write up**).

- **Invocation Property** states that a process from below cannot request higher access; only with subjects at an equal or lower level.

6.3 The Chinese Wall

The **Chinese Wall model**, by Brewer and Nash (1989), is not an integrity policy, but an access control confidentiality policy addressing conflict of interests. It entails:

- **Objects** such as files. Objects contain information about only one company.
- **Company groups**, which collect all objects concerning a particular company.
- **Conflict classes** cluster the groups of objects for competing companies.

Rules:

- **(Chinese Wall) Simple Security Rule:** A subject s can be granted access to an object o only if the object:
 - is in the same company datasets as the objects already accessed by s , that is, “within the Wall,” or
 - belongs to an entirely different conflict of interest class.
- **(Chinese Wall) Star-property:** Write access is only permitted if:
 - access is permitted by the simple security rule, and
 - no object can be read which is in a different company dataset than the one for which write access is requested, and contains unsanitized information.